RISK MANAGEMENT PLAN
CYBR 610
PREPERED BY EZRA SHUREMU

Ezra Shuremu

BELLEVUE UNIVERSITY

Table of Contents

1. Introduction
2. Scope and Boundaries
3. Compliance Laws and Regulations
4. Key Roles and Responsibilities
5. Chief Risk Officer Implementation Timeline
6. Qualitative Risk Assessment Plan
7. Risk Mitigation Plan
8. Business Impact Analysis (BIA)
9. Business Continuity Plan (BCP)
10. Communication Plan During Disruption
11. Roles and Responsibilities
12. Recovery Phase and Alternate Site Operations
13. Reconstitution and Return to Normal
14. BCP Testing, Training, and Maintenance
15. Conclusion
16. References

1. Introduction

In an era of increasing complexity and interconnectivity, risk management is a vital component of any organization’s strategic and operational planning. As organizations rely more heavily on digital systems, cloud computing, remote work environments, and cross-functional collaboration, they also become more susceptible to a range of internal and external threats. These threats can affect operational continuity, data privacy, legal compliance, customer trust, and even the organization's long-term viability. The purpose of this Risk Management Plan is to establish a structured approach to identifying, analyzing, responding to, and monitoring risks that may adversely impact the organization.

Risk is an inherent part of doing business, but unmanaged risk can lead to disruptions, financial loss, regulatory penalties, and reputational damage. Conversely, proactive and well-structured risk management can serve as a strategic advantage. It empowers the organization to navigate uncertainty with confidence, make informed decisions, allocate resources efficiently, and comply with regulatory requirements. Through this plan, the organization aims to instill a culture of risk awareness, encourage collaboration across departments, and integrate risk considerations into everyday business practices.

This document outlines the foundational structure of the risk management process, including definitions of responsibilities, compliance obligations, risk identification techniques, and assessment criteria. While this version focuses primarily on the preliminary elements—such as purpose, scope, legal compliance, and roles—it will evolve over time to include detailed qualitative assessments, mitigation strategies, and continuous monitoring mechanisms. This living document is designed to be reviewed and updated regularly, ensuring it remains aligned with industry standards, technological developments, and the organization’s changing risk landscape.

By adopting this plan, the organization affirms its commitment to responsible governance, sustainable operations, and ethical conduct. Whether managing cybersecurity threats, responding to regulatory changes, or anticipating operational disruptions, our approach will be consistent, documented, and aligned with best practices. Risk management is not a one-time initiative—it is an ongoing process that supports resilience, innovation, and trust among stakeholders.

2. Scope and Boundaries

This Risk Management Plan applies to all departments, personnel, systems, and operations at Health Network Inc., with a primary focus on the Arlington Data Center and corporate offices. The scope includes all aspects of organizational infrastructure such as:

- Information Technology Systems: Networks, servers, software applications, databases, and cloud services used throughout the organization.
- Operational Business Units: Finance, Human Resources, Legal/Compliance, Customer Support, and IT operations.
- Facilities: Physical premises including office spaces, data centers, and equipment storage areas.
- Personnel: All full-time employees, contractors, consultants, and third-party service providers.
- Regulatory Compliance Requirements: Activities governed by HIPAA, GDPR, SOX, FISMA, and other applicable federal and state regulations.

Boundaries include excluding personal systems not used for business operations, unregulated departments with minimal risk exposure, and non-operational or archived infrastructure no longer in active use. The plan emphasizes enterprise-level risks that may disrupt mission-critical activities or violate compliance standards, rather than speculative or minor concerns.

3. Compliance Laws and Regulations

This Risk Management Plan adheres to several key laws and regulatory frameworks to ensure legal compliance and protection of sensitive data:

- Health Insurance Portability and Accountability Act (HIPAA): Regulates the use and disclosure of protected health information (PHI) in the healthcare sector, enforcing administrative, technical, and physical safeguards.
- General Data Protection Regulation (GDPR): Applies to any organization that processes the personal data of EU citizens, mandating strict privacy protections, data subject rights, and breach notification.

- Sarbanes-Oxley Act (SOX): Enforces financial reporting standards and internal controls for publicly traded companies to prevent corporate fraud and ensure transparency.
- Federal Information Security Modernization Act (FISMA): Sets forth information security requirements for federal agencies and their contractors, emphasizing a risk-based approach to securing IT systems.
- NIST SP 800-66 Rev. 2: Provides guidelines for implementing the HIPAA Security Rule through a framework of security standards and best practices.

Compliance with these regulations is essential for safeguarding organizational assets, maintaining public trust, and avoiding legal or financial penalties. The plan incorporates these frameworks into every aspect of risk identification, mitigation, monitoring, and reporting.

4. Key Roles and Responsibilities

Role	Responsibility
Chief Risk Officer (CRO)	Oversees the enterprise-wide risk strategy, ensures alignment with strategic goals
IT Security Team	Implements cybersecurity controls, conducts vulnerability assessments
Compliance Officer	Monitors regulatory updates, manages audits, ensures policy adherence
Risk Management Committee	Reviews risk assessments and mitigation plans, approves critical decisions
All Employees	Required to follow risk-related policies and report potential risks or violations

5. Chief Risk Officer Implementation Timeline

Phase	Timeline
Risk Identification & Assessment	April 1 – April 14
Compliance & Legal Risk Review	April 15 – April 21
Risk Mitigation Strategy Development	April 22 – May 5
Draft Risk Plan Review	May 6 – May 10
Implementation of Mitigation Plans	May 13 – May 24
Monitoring and Review	Ongoing (monthly)

6. Qualitative Risk Assessment Plan

The Qualitative Risk Assessment Plan provides a structured methodology for identifying, evaluating, and prioritizing risks based on their likelihood and potential

impact. It is intended to inform decision-making and guide the implementation of appropriate mitigation strategies within Health Network Inc.

Objectives

- Identify key information assets and business functions
- Evaluate the potential threats and vulnerabilities
- Determine the likelihood and impact of each identified risk
- Prioritize risks based on a defined risk matrix
- Recommend appropriate control measures

Scope

This assessment covers the following domains:

- Information Technology infrastructure (networks, servers, databases)
- Healthcare information systems (electronic medical records, patient data)
- Financial systems (billing and payment platforms)
- Human resources and operational procedures

Methodology

Risks will be evaluated using a qualitative risk matrix that maps probability against impact. Each risk will be categorized as Low, Medium, or High. Key steps include:

1. Risk Identification
2. Risk Analysis (likelihood and impact rating)
3. Risk Evaluation (ranking and categorization)
4. Risk Treatment recommendations

Roles and Responsibilities

Role	Responsibility
Chief Risk Officer	Oversees risk identification and assessment process
IT Security Team	Identifies technical risks and evaluates system vulnerabilities
Department Heads	Provide operational insights and identify process-level risks
Compliance Officer	Ensures all assessments meet regulatory standards

Risk Assessment Schedule

Task	Timeline
Asset Inventory Completion	May 29 – May 31
Threat and Vulnerability Mapping	June 1 – June 4
Risk Likelihood and Impact Analysis	June 5 – June 10
Risk Evaluation and Documentation	June 11 – June 14
Final Risk Review Meeting	June 15

This plan ensures that Health Network Inc. adopts a consistent and objective approach to managing its enterprise risks.

7. Risk Mitigation Plan

The Risk Mitigation Plan outlines strategic actions and safeguards designed to minimize the impact of identified risks on Health Network Inc.'s systems, operations, and services.

Objectives

- Implement controls that prevent or reduce threats
- Assign responsibility for mitigation actions
- Align mitigation strategies with compliance standards

Risk Categories and Mitigation Strategies

Risk Category	Example Threat	Mitigation Strategy
Cybersecurity	Phishing, ransomware	Deploy email filters, conduct staff awareness training, implement MFA
Operational	Equipment failure	Perform regular maintenance, maintain vendor SLAs, deploy redundant systems
Compliance	HIPAA/GDPR violations	Conduct regular audits, ensure access controls, update policies periodically
Environmental	Winter storm disrupting services	Establish remote work capabilities, maintain alternate power sources
Insider Threat	Employee sabotage or error	Enforce role-based access controls, monitor activities, train staff

Implementation Tactics

- Prioritize high-risk areas identified in the assessment
- Develop mitigation workflows with assigned timelines
- Monitor progress through monthly risk committee reviews

This plan ensures Health Network Inc. is positioned to proactively respond to potential risks and reduce their operational and reputational impact.

8. Business Impact Analysis (BIA)

The Business Impact Analysis (BIA) identifies and evaluates the potential effects of disruptions to critical business operations due to disasters, emergencies, or other unexpected events. It informs the development of continuity and recovery strategies.

Objectives

- Identify and prioritize critical business functions
- Estimate the impact of disruption on each function
- Define acceptable downtime limits and recovery priorities

Key Components

1. Critical Business Functions
    - Electronic Health Records (EHR) System
    - HNetExchange and HNetConnect platforms
    - Customer Support Services

    - Financial Systems (billing, claims)
2. Critical Resources
    - Network Infrastructure
    - Power Supply and HVAC
    - Skilled Staff (IT, medical, finance)
    - Communication Systems
3. Impact Categories
    - Financial Loss
    - Legal and Regulatory Penalties
    - Reputational Damage
    - Patient Safety Risks

Maximum Acceptable Outage (MAO), Recovery Time Objective (RTO), Recovery Point Objective (RPO)

Function	MAO	RTO	RPO
EHR System	24 hours	8 hours	2 hours
HNetExchange	12 hours	6 hours	1 hour
Financial Systems	48 hours	12 hours	4 hours
Customer Support	24 hours	8 hours	2 hours

Disruption Scenario: Winter Storm

Scenario: A severe winter storm shuts down the Arlington Data Center, disrupting connectivity and systems access.

Impact Assessment:

- EHR and HNetExchange services are inaccessible
- Communication with patients and internal staff is delayed
- Regulatory compliance at risk if data backup processes fail

Response Strategies:

- Failover to alternate cloud-based systems
- Redirect support to Minneapolis and St. Paul offices
- Notify staff and patients using emergency communication tools

This BIA serves as a foundation for recovery planning and resource prioritization across Health Network Inc.

9. Business Continuity Plan (BCP)

The Business Continuity Plan (BCP) outlines the strategies and procedures to ensure Health Network Inc. can maintain essential operations during and after a disruption.

Objectives

- Maintain critical functions during emergencies
- Minimize downtime and data loss
- Ensure rapid recovery and return to normal operations

BCP Activation and Response

1. Plan Activation
    - Initiated by the Incident Manager upon detection of a major disruption
    - Notification sent to continuity team members and executive leadership
2. Initial Response Procedures
    - Ensure staff safety and assess damage
    - Activate emergency communication channels
    - Transition operations to alternate locations or systems if necessary

Alternate Work Procedures

Function	Alternate Procedure
Customer Service	Use remote call centers from Minneapolis and St. Paul
EHR Access	Switch to secure cloud-based backup system
Billing and Claims	Enable remote VPN access for finance staff
Internal Communication	Use encrypted messaging platform for continuity team updates

System Recovery Strategies

- Establish recovery priorities based on the BIA (e.g., EHR first, then billing)
- Implement data recovery from secure cloud backups
- Test critical system functionality before full production use

The BCP is reviewed and updated annually or following a major incident to ensure its relevance, effectiveness, and alignment with new risks or technologies.

10. Communication Plan During Disruption

Effective communication is essential during a disruption to ensure timely coordination, minimize confusion, and preserve stakeholder trust. This plan outlines the strategies for internal and external communication before, during, and after a disruption event.

Internal Communication

- Activate internal messaging platforms (e.g., Teams, Signal) for real-time updates
- Distribute status reports to staff through email and text alerts
- Conduct daily virtual briefings for continuity and response teams

External Communication

- Notify patients and vendors of service disruptions via email, website banner, and social media
- Maintain a public status page to provide ongoing updates
- Assign a designated spokesperson to handle media inquiries and public statements

Communication Infrastructure Resilience

- Redundant communication systems (internet failover, secondary mobile networks)
- Emergency power sources to support communication servers and VoIP systems
- Secure cloud-based tools for remote access and messaging continuity

Clear communication protocols reduce panic, improve response efficiency, and support organizational transparency during critical events.

11. Roles and Responsibilities

This section identifies key roles during continuity and recovery phases, detailing who is responsible for initiating the BCP, coordinating response efforts, and executing restoration procedures.

Continuity Roles and Tasks

Role	Responsibilities
Incident Manager	Activates the BCP, leads crisis response, communicates with executive leadership
Continuity Coordinator	Ensures all continuity procedures are followed, documents actions taken
IT Recovery Lead	Restores IT systems, confirms availability of backup data
Facilities Coordinator	Manages access to facilities, arranges alternate site logistics
HR Liaison	Communicates workforce plans, supports employee needs

Support Teams

- Executive Management: Approves strategic decisions and oversees compliance
- Legal and Compliance: Ensures legal obligations are met during disruption
- Communication Team: Coordinates messages to stakeholders and media

Each individual and team is trained in their role to support seamless coordination during and after a disruptive event.

12. Recovery Phase and Alternate Site Operations

The recovery phase begins immediately after the initial incident is stabilized. This phase focuses on restoring essential services and enabling Health Network Inc. to operate at a minimum acceptable level until full recovery is achieved.

Objectives

- Resume mission-critical functions
- Minimize disruption and patient care delays
- Ensure availability of secure systems and data

Recovery Phase Activities

1. Damage Assessment: Evaluate impacted infrastructure and systems
2. System Restoration: Restore IT, EHR, and communication platforms from backups
3. Personnel Coordination: Activate alternate staffing plans if needed
4. Documentation: Maintain logs of actions taken and decisions made

Alternate Site Operations

Health Network Inc. maintains readiness at pre-designated alternate sites:

- Minneapolis Office: Houses redundant systems and workstations
- St. Paul Office: Supports administrative and customer service operations

If the Arlington Data Center becomes inoperable:

- Cloud-hosted services and remote work protocols are activated
- Key systems failover to Minneapolis
- Internal operations are sustained using pre-arranged virtual collaboration tools

Recovery strategies are periodically tested and updated to align with emerging threats and organizational changes.

13. Reconstitution and Return to Normal

Once systems have been stabilized and critical operations are restored, the organization enters the reconstitution phase. This final phase ensures a controlled return to pre-disruption conditions.

Objectives

- Validate that systems are fully operational
- Transition staff and operations from alternate sites to primary locations
- Evaluate the success of recovery efforts and update documentation

Reconstitution Activities

1. System Validation: Verify that all systems, data, and communications are functioning correctly
2. Personnel Reassignment: Gradually transition staff back to primary work environments
3. Facility Restoration: Assess and restore physical infrastructure, equipment, and workspace
4. Audit and Documentation: Perform a post-incident review and log findings

Post-Recovery Review

- Conduct lessons learned meeting
- Update BCP documentation based on real-world outcomes
- Identify opportunities for improvement in training, infrastructure, and coordination

Successful reconstitution ensures that the organization not only returns to full operations but also emerges stronger and better prepared for future disruptions.

14. BCP Testing, Training, and Maintenance

An effective Business Continuity Plan requires continuous improvement through regular testing, employee training, and plan maintenance. These practices ensure readiness and adaptability in the face of new risks and organizational changes.

Testing Procedures

- Tabletop Exercises: Simulated scenario-based discussions to evaluate roles and decision-making processes
- Functional Drills: Hands-on simulations to test specific recovery capabilities (e.g., data restoration)
- Full-Scale Simulations: Organization-wide exercises to evaluate the entire BCP under real-world conditions

Employee Training

- Annual BCP awareness training for all staff
- Role-specific training for continuity team members
- Onboarding BCP training for new hires

Plan Maintenance

- Scheduled semi-annual BCP review and update
- Post-incident updates based on lessons learned
- Alignment with changes in IT systems, personnel, or facilities

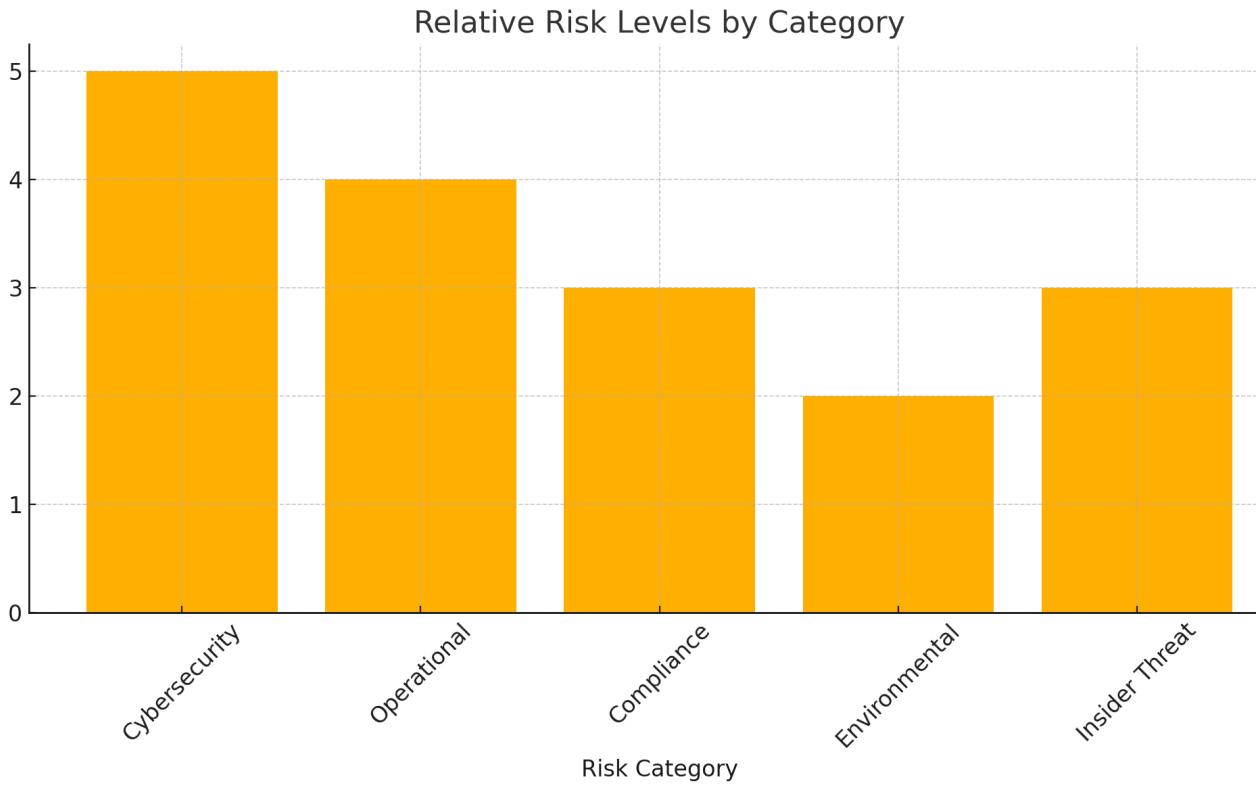
Regular testing and training foster a culture of resilience, while continuous updates ensure the plan remains relevant and actionable under evolving conditions.

15. Conclusion

This comprehensive Risk Management Plan, Business Impact Analysis, and Business Continuity Plan collectively strengthen Health Network Inc.'s ability to withstand, respond to, and recover from a wide range of potential threats. By adopting a proactive approach, the organization not only safeguards its critical assets and ensures regulatory compliance, but also fosters trust among its patients, partners, and staff.

The integration of structured risk assessments, mitigation strategies, continuity protocols, and recovery measures underscores the organization's commitment to operational resilience. As Health Network Inc. continues to evolve, this document serves as a living framework—subject to regular review and refinement—to align with technological advancements, emerging threats, and organizational growth.

By embedding resilience into the core of its operations, Health Network Inc. is positioned to sustain mission-critical services even under the most challenging circumstances, ensuring continuity of care and the long-term success of its mission.


Relative Risk Levels by Category
5
4
3
2
1
0
Cybersecurity
Operational
Compliance
Environmental
Insider Threat
Risk Category

16. References

- National Institute of Standards and Technology (NIST). (2022). NIST SP 800-30 Rev. 1: Guide for Conducting Risk Assessments.
- U.S. Department of Health & Human Services. (2022). HIPAA Security Rule.
- General Data Protection Regulation (GDPR). (2016). Regulation (EU) 2016/679.
- U.S. Congress. (2002). Sarbanes-Oxley Act (SOX).
- Office of Management and Budget (OMB). (2021). Federal Information Security Modernization Act (FISMA) Implementation Project.
- Frigo, M.L., & Anderson, R.J. (2011). Strategic Risk Management: A Foundation for Improving Enterprise Risk Management and Governance. Journal of Corporate Accounting & Finance.